# PHP2Shell: qué hacer si tu sitio usa WordPress (o similar)

Instructivo para personas no técnicas · CVE-2026-109618 y CVE-2026-109619

Actualizado el 26 de octubre de 2026 · Elaborado por un estudiante de Técnico en Ciberseguridad

**Qué hacer hoy**

- El fallo está en **PHP**, el motor que tu hosting pone debajo. Actualizar WordPress, themes o plugins **no lo arregla**.
- Averigua tu versión de PHP. Toma dos minutos y no tocas nada.
- Pídele el parche a tu proveedor o, si tu panel lo permite, cambia la versión tú.
- Mientras tanto, pon un firewall web (WAF) delante de tu sitio.
- Revisa si tu sitio ya fue comprometido, incluso si ahora está parchado.

## El problema en pocas palabras

El 21 de octubre de 2026 el equipo de PHP publicó parches de emergencia para dos vulnerabilidades críticas, CVE-2026-109618 y CVE-2026-109619, ambas con puntaje CVSS v4.0 de 9,2. Permiten que alguien, desde internet, haga que tu servidor ejecute código **sin necesidad de usuario ni contraseña**. Los detalles se filtraron antes del parche y se han reportado intentos de explotación activos.

Tu papel no es actualizar PHP. Tu papel es **exigir que se actualice, verificarlo y reducir el riesgo mientras tanto**.

### Versiones que corrigen el fallo

| Rama de PHP | Versión corregida | Observación |
|---|---|---|
| 8.5 | **8.5.12** | Soporte activo hasta diciembre de 2027. |
| 8.4 | **8.4.27** | Soporte activo hasta diciembre de 2026; seguridad hasta diciembre de 2028. |
| 8.3 | **8.3.36** | Solo correcciones de seguridad, hasta diciembre de 2027. |
| 8.2 | **8.2.35** | Parchada, pero llega a fin de vida el 31 de diciembre de 2026. Si vas a migrar, elige una rama más nueva. |
| 8.1 y anteriores | **Sin parche** | Sin soporte oficial: hay que migrar. Algunos proveedores aplican parches propios (*backports*); pregúntales. |

**Ojo:** si tu hosting solo dice “PHP 8.3”, no basta. Necesitas el número completo (por ejemplo, 8.3.36).

### ¿Esto me afecta?

- **Hosting compartido, VPS o servidor propio con PHP:** sí, esto aplica.
- **Shopify, Wix, Squarespace:** el proveedor administra la plataforma, así que no tienes un PHP propio que parchear. Si te preocupa, revisa su comunicado oficial.

- El riesgo es mayor con Apache y *mod_php*, donde un exploit demostrado dispara el fallo antes de que corra el código de tu aplicación. Con PHP-FPM la ruta demostrada requiere además una operación adecuada en la aplicación. Aun así, trata todo sitio sin parchar como expuesto.

## Averigua qué versión de PHP usa tu sitio

No confíes solo en lo que anuncia el panel de tu hosting: a veces muestra una cosa y el servidor ejecuta otra. La forma más fiable, desde dentro de WordPress:

» Entra a `tusitio.com/wp-admin`.

» En el menú lateral ve a **Herramientas > Salud del sitio**.

» Abre la pestaña **Información** (arriba a la derecha).

» Despliega la sección **Servidor** y mira la línea **Versión de PHP**.

| Lo que ves | Qué significa | Qué hacer |
|---|---|---|
| 8.5.12, 8.4.27, 8.3.36, 8.2.35 o superior | **Parchado** | Pasa a la sección *Verifica si tu sitio fue comprometido*. |
| 8.1, 8.0, 7.4 o inferior | **Riesgo máximo.** Sin parche oficial. | Ve ya a *Habla con tu proveedor*. |
| Una rama 8.2 a 8.5 con número menor al de arriba (por ejemplo, 8.4.20) o sin número final | **Sin parche o información incompleta.** | Anótalo y habla con tu proveedor. |

Si tu proveedor usa paquetes del sistema operativo, el número puede verse antiguo aunque el parche esté aplicado (*backport*). Por eso conviene preguntarle por escrito.

## Habla con tu proveedor de hosting

En hosting compartido, el proveedor es el único que controla PHP. Abre un ticket o un chat y copia este mensaje, cambiando lo que está entre corchetes:

```
Asunto: Consulta urgente - parche de seguridad PHP2Shell
(CVE-2026-109618 / CVE-2026-109619)

Hola:
Escribo para confirmar si la instalación de PHP que sirve a mi dominio
[tu-dominio.com] ya fue actualizada con el parche de seguridad para las
vulnerabilidades PHP2Shell (CVE-2026-109618 y CVE-2026-109619),
publicado el 21 de octubre de 2026.

La versión que veo desde WordPress es [pega aquí el número que anotaste].

¿Podrían confirmarme por escrito:
- la versión exacta y completa de PHP que se está ejecutando ahora
  mismo (por ejemplo, 8.3.36)?
- si los servicios de PHP (FPM/Apache) se reiniciaron después de
  aplicar el parche?
- si mi sitio ya está protegido o, si no, para cuándo lo estará?

Gracias.
```

**Si tu panel lo permite, puedes actuar tú.** Muchos paneles (cPanel, Plesk u otros) traen un selector de versión de PHP. Haz un respaldo primero, elige una versión parchada y comprueba que tu sitio siga funcionando. Si algo se rompe, vuelve a la versión anterior y consulta con soporte o con quien mantiene tu sitio. Después, vuelve a revisar el número completo en Salud del sitio.

### Cómo interpretar la respuesta

| Respuesta | Interpretación |
|---|---|
| Confirman versión parchada **y** reinicio del servicio | **Ideal.** Pasa a verificar si hubo compromiso. |
| Dicen que aplicaron un *backport* | **Aceptable**, pero pide el número de compilación exacto del paquete para poder verificarlo. |
| Responden “WordPress está actualizado” o “eso es cosa tuya” | **Incorrecto.** El fallo está en PHP. Insiste citando las CVE. Si dan largas, es una señal sobre qué tan en serio se toman tu seguridad. |

> **Consejo**
>
> Guarda el ticket. Si más adelante hay un incidente, demuestra si pediste la actualización y cuándo.

## Pon un WAF mientras esperas

Un firewall de aplicaciones web (WAF) se coloca delante de tu sitio y filtra tráfico malicioso antes de que llegue a tu servidor. **Reduce el riesgo, pero no lo elimina**: depende de que sus reglas reconozcan el intento, y ninguna regla cubre todas las variantes.

- Crea una cuenta gratuita en un servicio como Cloudflare, cuyo plan gratuito alcanza para empezar.
- Sigue el asistente para añadir tu dominio.
- Cambia los *nameservers* donde compraste el dominio por los que te indique el asistente.
- Activa las reglas de protección administradas que ofrezca el servicio.

Si no puedes cambiar los *nameservers*, pregunta a tu proveedor si ofrece un WAF propio.

> **Importante**
>
> El WAF no reemplaza el parche. Es una capa extra de defensa, no una cura. Los intentos de explotación son masivos y automatizados, así que ponerlo ayuda, pero seguir esperando el parche no es una opción.

## Verifica si tu sitio fue comprometido

Un parche cierra la puerta, pero no expulsa a quien ya entró. Como este fallo permite ejecutar código sin dejar rastro visible en la página, hay que buscar señales indirectas. Si notas **cualquiera** de estas, trátalo como alarma:

- [ ] **Cuentas de administrador desconocidas.** En WordPress ve a Usuarios: todos los administradores deben ser personas que conoces.
- [ ] **Archivos `.php` dentro de `wp-content/uploads`.** Revisa con el administrador de archivos de tu panel. Ahí solo debería haber imágenes, PDF y similares.

- [ ] **Archivos o tareas programadas que no reconoces**, o archivos como `wp-config.php` o `.htaccess` modificados sin que tú lo hayas hecho.
- [ ] **Sitio lento o CPU del servidor disparada** sin un aumento de visitas.
- [ ] **Errores repetidos de "Allowed memory size exhausted"** en los registros de errores del hosting. Pueden ser señal de intentos de explotación.
- [ ] **Peticiones POST multipart inusuales** en los registros del servidor.

> **Si detectas algo**
>
> No borres nada ni reinicies el servicio por tu cuenta. Avisa de inmediato a tu proveedor y pídele que preserve la evidencia (registros y estado del servidor) antes de reiniciar o parchar ese servidor, porque reiniciar borra el estado en memoria que aprovecha CVE-2026-109619 y que sirve para investigar. No pospongas el parche más de lo que tome eso. Si puedes, suma a un profesional de seguridad.

### Si crees que te comprometieron

- Avisa al proveedor y pide que preserve la evidencia, como se explicó arriba.
- Pon el sitio en mantención o pide que lo aíslen mientras lo limpian.
- Asegúrate de que PHP ya esté parchado antes de seguir. Si no, el atacante puede volver a entrar.
- Restaura desde un respaldo limpio, anterior al compromiso, o pide una reinstalación limpia. Limpiar a mano rara vez es suficiente.
- Cambia todas las credenciales: panel de hosting, FTP/SFTP, base de datos, administradores de WordPress, las claves y *salts* de `wp-config.php` y cualquier clave de API guardada en el sitio. Hazlo cuando el servidor ya esté parchado y limpio, y desde un equipo de confianza.
- Comprueba la integridad de los archivos. Si tu proveedor ofrece WP-CLI, `wp core verify-checksums` y `wp plugin verify-checksums --all` comparan tus archivos con los originales.
- Si el sitio guarda datos de clientes, consulta con un profesional qué obligaciones de aviso te aplican y considera informar al CSIRT Nacional (ANCI).

## Para quienes sí administran el servidor

La solución es el parche. Actualiza **todas** las versiones de PHP instaladas, aunque tus sitios no las usen, confirma con `php -v` y reinicia PHP-FPM o Apache. Las actualizaciones automáticas del sistema pueden no incluir PHP si se instaló desde un repositorio aparte. En contenedores, reconstruye la imagen con la versión parchada.

### Mitigaciones temporales, solo si hoy no puedes parchar

| Fallo | Medida temporal | Notas |
|---|---|---|
| CVE-2026-109618 | Fijar `memory_limit = -1` de forma obligatoria con `php_admin_value` en todos los *pools* y directorios. Bloquear peticiones multipart en el frontend si no las usas. | Quita el tope de memoria: úsalo solo como medida temporal y vigila el consumo de recursos. |
| CVE-2026-109619 | Fijar `session.upload_progress.enabled = 0`. | Debe ir en `php.ini` o en la configuración del servidor, **no** con `ini_set()` ni `.user.ini`. En PHP 8.5, agrega `fatal_error_backtraces = 0`. |

```
; php.ini (temporal; no reemplaza el parche)
session.upload_progress.enabled = 0
memory_limit = -1
fatal_error_backtraces = 0     ; solo PHP 8.5

; En un pool de PHP-FPM, para fijar el límite de forma obligatoria:
php_admin_value[memory_limit] = -1
```

Después de cambiar la configuración, reinicia PHP-FPM o Apache. Ojo: desactivar `session.upload_progress` bloquea una sola ruta demostrada de CVE-2026-109619 y no hace nada contra CVE-2026-109618. Estas medidas son parciales; **la única solución completa es el parche**.

## Mitos comunes

| Mito | Realidad |
|---|---|
| “Actualizo WordPress y ya estoy protegido.” | Falso. El fallo está en PHP, no en WordPress. |
| “Mi plugin de seguridad me protege.” | Falso. El fallo se dispara antes de que corra el código de tu aplicación, así que un plugin no te cubre. |
| “No soy un objetivo interesante.” | Falso. La mayoría de los intentos son bots automatizados que escanean todo internet sin elegir víctimas. |
| “Si no veo nada raro, estoy bien.” | Falso. El fallo permite ejecutar código sin rastro visible. Hay que buscar señales indirectas. |
| “Espero a que mi hosting avise.” | Riesgoso. Abre tú el ticket y pide la confirmación por escrito. |
| “Con el WAF ya no necesito el parche.” | Falso. El WAF es defensa adicional, no un sustituto. |

## Cuidado con las estafas

En crisis como esta aparecen correos y mensajes que suplantan a PHP, a WordPress o a tu proveedor, pidiéndote hacer clic en una “actualización de seguridad urgente”. Ese enlace suele llevar a *phishing* o a malware.

> **Regla de oro**
>
> Nunca hagas clic en enlaces de actualizaciones que no pediste. Entra siempre escribiendo tú mismo la dirección del panel de tu hosting o de WordPress.

Si trabajas en seguridad, desconfía también de repositorios que dicen ser pruebas de concepto de PHP2Shell: ya se han visto copias con malware dirigidas a profesionales. No ejecutes herramientas de fuentes no verificadas.

## Glosario

| Término | Qué significa |
|---|---|
| PHP | El lenguaje que usan la mayoría de los sitios web para funcionar. Es el “motor” bajo WordPress. |
| CVE | Identificador público único de una vulnerabilidad conocida. |
| RCE | Ejecución remota de código: un atacante hace que el servidor ejecute instrucciones que él elige, desde internet. |
| CVSS | Escala de 0 a 10 de gravedad. De 9,0 en adelante se considera crítico. |
| Parche | Actualización que corrige el fallo. |
| Backport | Aplicar el parche de seguridad a una versión antigua sin cambiar de versión. |
| EOL (fin de vida) | Versión que ya no recibe parches de seguridad. |
| WAF | Firewall de aplicaciones web: filtra tráfico malicioso antes de que llegue a tu servidor. |

## Fuentes y aviso

Este instructivo se basa en información pública disponible al 26 de octubre de 2026. La situación sigue evolucionando: verifica los datos con las fuentes y con tu proveedor. Es material divulgativo y no sustituye el asesoramiento de un profesional.

- Help Net Security (helpnetsecurity.com)
- Cyber Centre de Canadá, alerta AL26-026 (cyber.gc.ca)
- Tanium (tanium.com)
- Armis (ServiceNow) (servicenow.com)
- HeroDevs (herodevs.com)
- Laravel Forge (laravel.com)
- Sevalla (docs.sevalla.com)
- Soporte por rama de PHP (pasqualepillitteri.it)